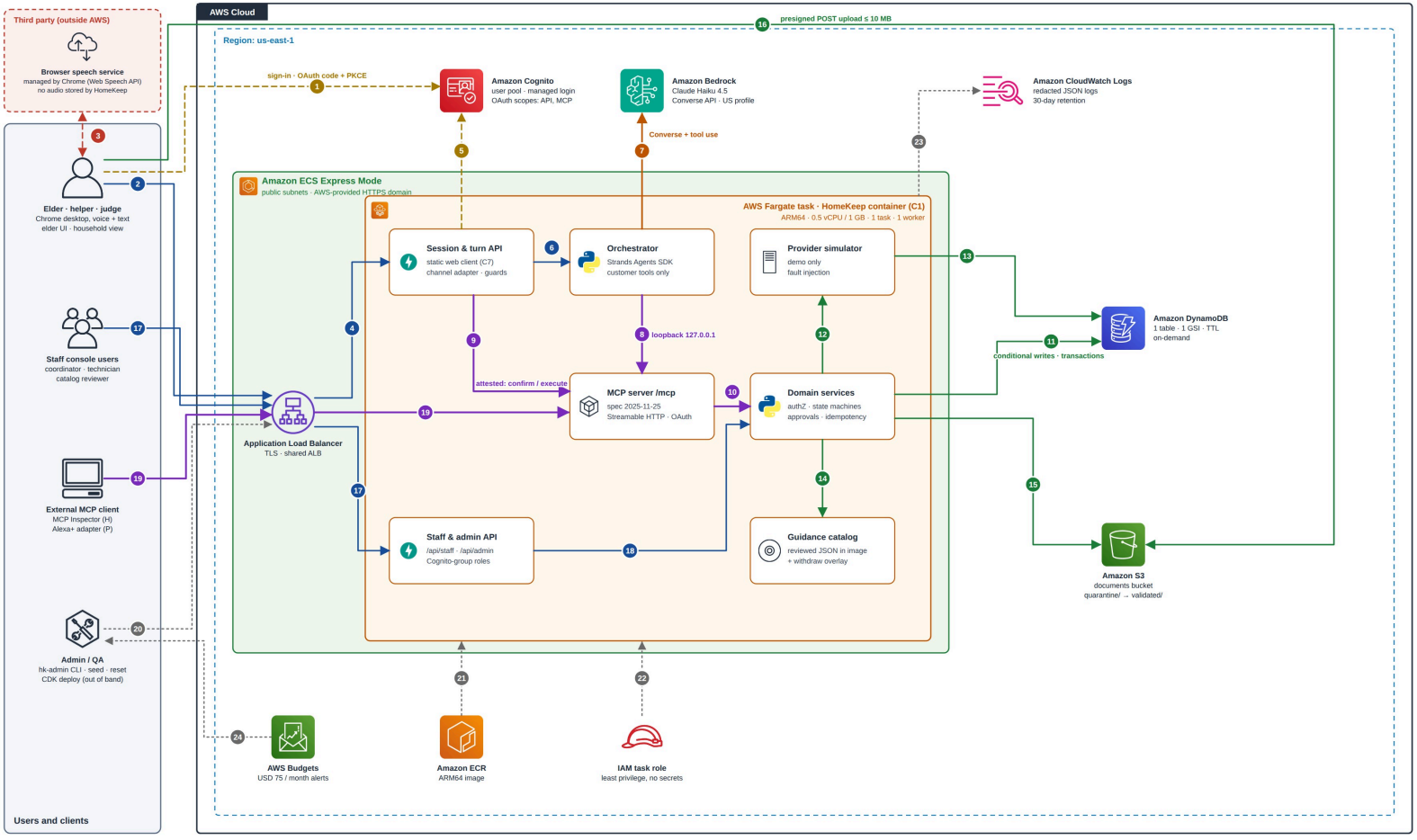
HomeKeep AWS Architecture — Interaction Guide

Hackathon release (H) · companion to HomeKeep TDD v1.0 and the architecture diagram · 26 September 2026



Legend

Line types

- HTTPS user / client traffic
- MCP protocol (Streamable HTTP, spec 2025-11-25)
- Model inference (Bedrock Converse)
- Data read / write
- Identity (sign-in, token verification)
- Platform and operations
- Third party, outside AWS

Numbered interactions

1. Sign in at Cognito managed login (OAuth code + PKCE)
2. Browser loads the app and posts turns over HTTPS with a Bearer JWT
3. Chrome converts speech to text and speaks replies; no audio reaches AWS
4. ALB routes /api/turns to the session and turn API
5. Every API verifies the JWT against Cognito JWKS
6. Turns not handled by deterministic guards go to the orchestrator
7. Orchestrator calls Bedrock Converse with tool use (Haiku 4.5)
8. Orchestrator calls its tools only through MCP over 127.0.0.1
9. Channel makes attested confirm / execute calls (hidden from the LLM)
10. MCP tools invoke domain services (tenant from token only)
11. Domain writes records, approvals and operation keys to DynamoDB
12. Domain submits, replaces, cancels and polls demo bookings
13. Provider simulator keeps slots and requests in DynamoDB
14. Domain reads published guidance and the withdraw overlay
15. Domain validates uploads and issues 5-minute presigned GETs
16. Helper or staff browser uploads documents directly to S3
17. Staff console reaches /api/staff through the ALB
18. Staff and admin API call the same domain services
19. External MCP client calls /mcp with a Cognito token (homekeep/mcp)
20. Admin CLI calls /api/admin (catalog, faults, purge, reset)
21. ECS pulls the ARM64 container image from ECR
22. Task assumes a least-privilege IAM role; no stored secrets
23. Container writes redacted structured logs to CloudWatch
24. Budgets emails the owner at 50%, 80% and 100% of USD 75

Not deployed (TDD Section 3.3)

AgentCore Runtime · Lambda · API Gateway · Step Functions
EventBridge Scheduler · SQS · Knowledge Bases · OpenSearch
Transcribe · Polly · CloudFront · Route 53 · Secrets Manager

Design notes

Only the HomeKeep container is custom code; everything else is managed.
Tenant scope comes from the token → membership lookup; no tool accepts a household ID argument.
Approvals are captured by the channel, never by the model: the agent's MCP client has no confirm / execute tools and no attestation.
Simulation mode is fixed server-side: H contains no live provider adapter, so no spoken command or document can trigger real dispatch.
Single task by design: 3 concurrent users need one worker; scale-up is a task-size change, multi-task is a P change (shared secret).

How to read this guide

Every arrow on the diagram carries a numbered badge. The number identifies the interaction, not the order it happens in: the same arrow is used by several flows. Part 1 explains each numbered arrow once. Part 2 walks through the application flows step by step, with the arrows each flow uses highlighted on the diagram and all others faded.

HTTPS user / client traffic · MCP protocol · Model inference · Data read / write · Identity · Platform and operations · Third party, outside AWS

In the step lists, badges show which arrows a step travels along. A **channel guard** step happens inside the session API with no arrow, where deterministic code (not the LLM) makes the decision.

Section	Content	Arrows used
Part 1	Reference: all 24 numbered interactions	1 2 3 4 5 6 7 8 9 10 11 12 13 14 15 16 17 18 19 20 21 22 23 24
Flow A	Sign-in and session start	1 2 3 4 5 6 7 8 10 11
Flow B	Everyday conversation turn	2 3 4 5 6 7 8 10 11 14
Flow C	Booking a demo technician with explicit approval	2 3 4 5 6 7 8 9 10 11 12 13
Flow D	Technician completes the visit; customer confirms the outcome	2 3 4 5 6 7 8 10 11 17 18
Flow E	Optional document upload and model verification	11 15 16 17 18
Flow F	External MCP client (judges; Alexa+ adapter in P)	10 11 12 13 14 19
Flow G	Platform, operations and test controls	20 21 22 23 24

Two principles to keep in mind while reading: (1) the LLM only ever proposes actions through MCP tools; anything consequential is approved and executed by the channel over arrow 9, which the LLM cannot use. (2) the household is always taken from the sign-in token, so no request can reach another household's data.

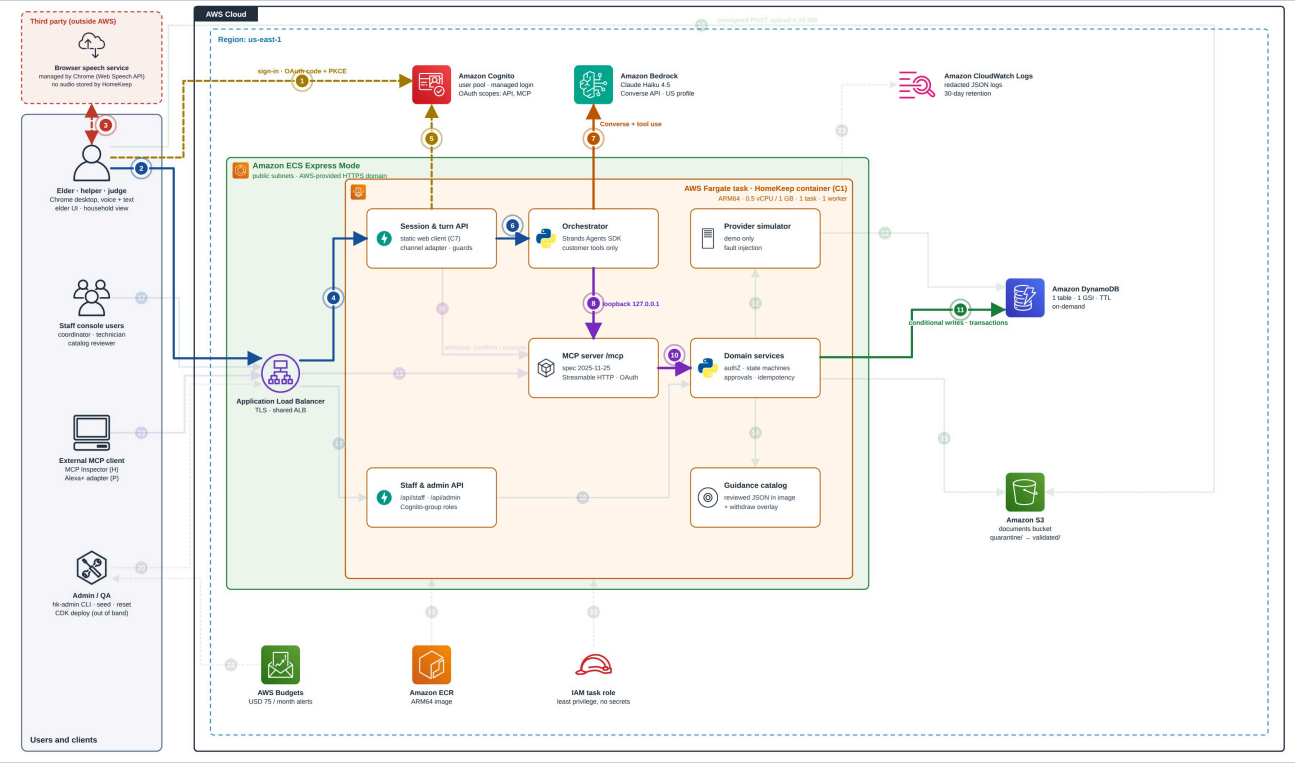
Part 1 — Reference: every numbered interaction

#	From → To	Channel	What happens	Why it matters
1	**Elder / helper / judge browser** → Amazon Cognito	OAuth 2.0 authorisation code + PKCE (managed login)	The user signs in once (assisted setup for an elder). Cognito returns an access token with scopes homekeep/api and homekeep/mcp, and a refresh token kept in sessionStorage so a page reload resumes without another sign-in. Staff sign in the same way.	Distinct authenticated actors, not a role switch (BRD §4). FR-01 assisted setup.
2	**Browser** → Application Load Balancer	HTTPS on the AWS-provided domain; Bearer JWT	Loads the web client, starts a session (POST /api/sessions) and sends each final utterance as POST /api/turns with turn_id (UUIDv7), text, speech-start and playback-end timestamps.	HTTPS is mandatory for microphone access. turn_id makes retries idempotent end to end (FR-22, NFR-05, NFR-11).
3	**Chrome (Web Speech API)** → Browser speech service	Browser-managed; outside AWS	Chrome converts the elder's speech to text (continuous recognition, en-IN) and speaks HomeKeep's replies. Only text ever reaches HomeKeep; no audio is stored.	Voice-first everyday use (BR-02, FR-21). Third-party processing documented per BRD §8.3.
4	**Application Load Balancer** → Session & turn API	HTTP inside the VPC	Routes the web client, /api/sessions and /api/turns to the channel adapter inside the Fargate task.	Single entry point; TLS ends at the ALB.
5	**Session & turn API (and every API)** → Amazon Cognito JWKS	HTTPS, cached public keys	Verifies the JWT signature, issuer, client, token type and expiry. The household and grant flags are then read from DynamoDB on every request, never from token claims.	Server-side authorisation and immediate revocation (NFR-04, FR-20).
6	**Session & turn API** → Orchestrator	In-process call	Only turns the deterministic guards did not handle go to the LLM. Guards first catch stop / repeat / slower commands, hazard phrases and approvals.	Integrity rules live in code, not prompts (DD-2).
7	**Orchestrator** → Amazon Bedrock	Converse API with tool use; Claude Haiku 4.5, US profile	The model interprets the utterance, picks MCP tools and writes a short spoken reply. At most 12 model/tool cycles per turn; prompt caching for the system prompt and tool schemas.	Conversation processing is real in H (BRD §9.5). Cost cap (NFR-12). Latency budget (NFR-01).
8	**Orchestrator** → MCP server /mcp	MCP 2025-11-25, Streamable HTTP over 127.0.0.1	The agent calls its tools only through a real MCP client. Each call carries the user's token, turn id, session id and correlation id. The agent sees customer tools only.	Meets the Alexa+ track rule that MCP is imported and actually called at runtime.
9	**Session & turn API (trusted client)** → MCP server /mcp	MCP plus X-HK-Attest HMAC header	After the channel has verified a spoken 'yes', it calls confirm_action and then execute_action. It also calls cancel_pending_action on stop/no and report_warning_sign on hazard phrases. These tools refuse any call without the attestation, and the LLM never has it.	Approval cannot be forged by the model or by document text (FR-12, BRD §9.3, AT-10, AT-13).
10	**MCP server** → Domain services	In-process call	Tools invoke domain services. Tenant scope comes from token → membership only; no tool accepts a household ID. The server derives operation keys and returns typed errors.	Tenant isolation (BRD §7.3), idempotency (NFR-05), actionable errors (FR-28).
11	**Domain services** → Amazon DynamoDB	Conditional writes and transactions	Stores households, appliances, issues, steps, service requests, appointments, approvals, operation keys, events and session checkpoints. A confirmed booking is one atomic transaction.	Persistence across restarts (BR-03, AT-11); no lost updates or duplicate dispatch (NFR-05).
12	**Domain services** → Provider simulator	In-process adapter contract	Checks serviceability, lists slots, submits with the operation key, reads status, replaces and cancels demo bookings. Reconciliation runs on read, on resume and every 60 s.	Simulated service desk that must be disclosed (C07, BR-04, FR-13 to FR-15).
13	**Provider simulator** → Amazon DynamoDB	Conditional writes	Keeps slot inventory (last slot taken by exactly one user), provider requests de-duplicated by operation key, and admin fault-injection settings.	Contention and timeout tests (AT-14, AT-15).

#	From → To	Channel	What happens	Why it matters
14	**Domain services** → Guidance catalog	In-memory lookup + DynamoDB status overlay	Returns approved steps only for a verified exact model and symptom category, with source locator and evidence text. Otherwise it returns NO_APPROVED_GUIDANCE with a reason. Withdrawn items are blocked at runtime.	Evidence-based guidance (BR-05, FR-08, FR-23, AT-04, AT-24).
15	**Domain services** → Amazon S3	AWS SDK	Issues presigned upload forms, validates each upload (size and file signature), moves it from quarantine/ to validated/, and issues 5-minute presigned GETs for authorised viewers.	Optional document enrichment (FR-04, AT-05, NFR-07).
16	**Helper or staff browser** → Amazon S3	HTTPS presigned POST	The browser uploads a PDF, JPEG or PNG (≤ 10 MB) straight to quarantine/ using the presigned form; the file never passes through the container.	Documents are optional and never block reporting or booking (FR-04-AC1).
17	**Staff console** → ALB → Staff & admin API	HTTPS, Bearer JWT (Cognito groups)	Coordinators and technicians open their queue and case views, and post service events such as VISIT_COMPLETED.	Staff surface (BRD §11.3).
18	**Staff & admin API** → Domain services	In-process call	The same domain services apply role and assignment checks. Each event needs an event_id (de-duplication) and expected_version (older events cannot regress state).	FR-16, FR-17, AT-18, AT-35.
19	**External MCP client (MCP Inspector; Alexa+ in P)** → ALB → MCP server /mcp	MCP 2025-11-25, Streamable HTTP, OAuth Bearer	Discovers the authorisation server from /.well-known/oauth-protected-resource, signs in at Cognito with the mcp-inspector client, then lists and calls customer tools. It can prepare an action but not approve one.	Proves a reusable, externally reachable MCP surface for judges; the path an Alexa+ adapter would use in P (FR-26).
20	**Admin / QA (hk-admin CLI)** → ALB → /api/admin	HTTPS, admin-group JWT	Withdraws catalog items, sets provider fault injection for tests, manages grants, purges a test household, resets a judge household. All actions are audited.	FR-23, FR-24, BRD §11.4.
21	**Amazon ECR** → ECS Fargate task	Image pull	ECS pulls the ARM64 container image on each deploy or task restart.	Reproducible deployment (NFR-10).
22	**IAM task role** → ECS Fargate task	Temporary credentials	The task receives least-privilege credentials for DynamoDB, S3, Bedrock and one Cognito admin call. No secrets are stored anywhere.	Secure transport and access (NFR-11).
23	**HomeKeep container** → CloudWatch Logs	ECS log driver	Structured JSON logs with an allowlist of fields: correlation id, hashed actor, action, result, latency, token counts. No transcripts, addresses or tokens.	Observability without leaking personal data (NFR-07, NFR-09).
24	**AWS Budgets** → Owner (email)	Budget alerts	Emails the owner at 50%, 80% and 100% of a USD 75 monthly budget.	Cost control while the demo stays live to 20 November (NFR-12).

Part 2 — Flow A: Sign-in and session start

> *A helper opens HomeKeep in Chrome for the elder and signs in once. The session begins.*

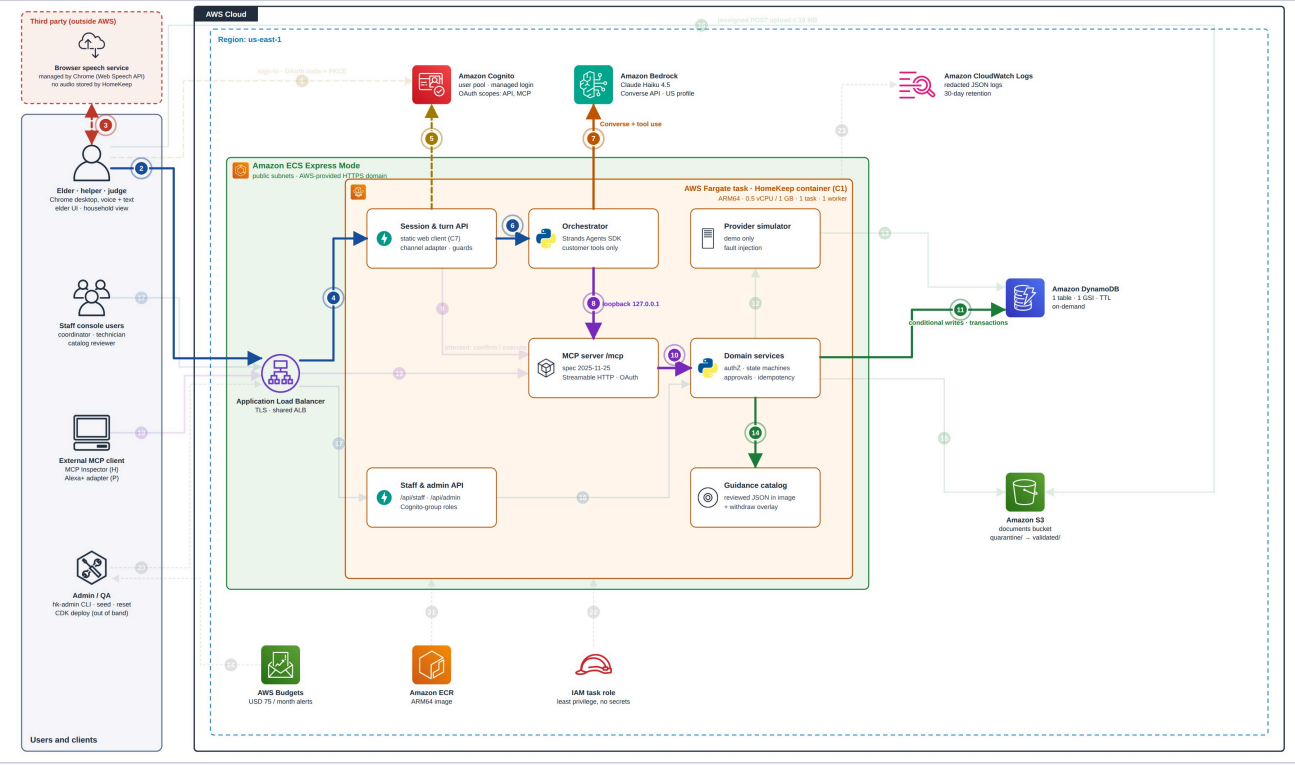


1. 1 The browser redirects to Cognito managed login; the helper signs in. Cognito returns tokens to the app (PKCE, no client secret).
2. 2 4 The client calls POST /api/sessions with the Bearer token. The ALB routes it to the session API.
3. 5 11 The API verifies the token against Cognito's keys, then reads the membership, grants and consent status from DynamoDB.
4. 6 7 8 10 11 The orchestrator calls get_context through MCP: appliances, open issues, active bookings (reconciled), due reminders. If storage consent is missing, the first reply is the consent question.
5. 3 Chrome speaks the greeting and starts listening. From here the elder needs no clicks.

> Consent itself is captured like any other approval (Flow C steps 5–7), with kind CONSENT_STORAGE.

Part 2 — Flow B: Everyday conversation turn

> *Elder: “The bedroom AC is not cooling.”*

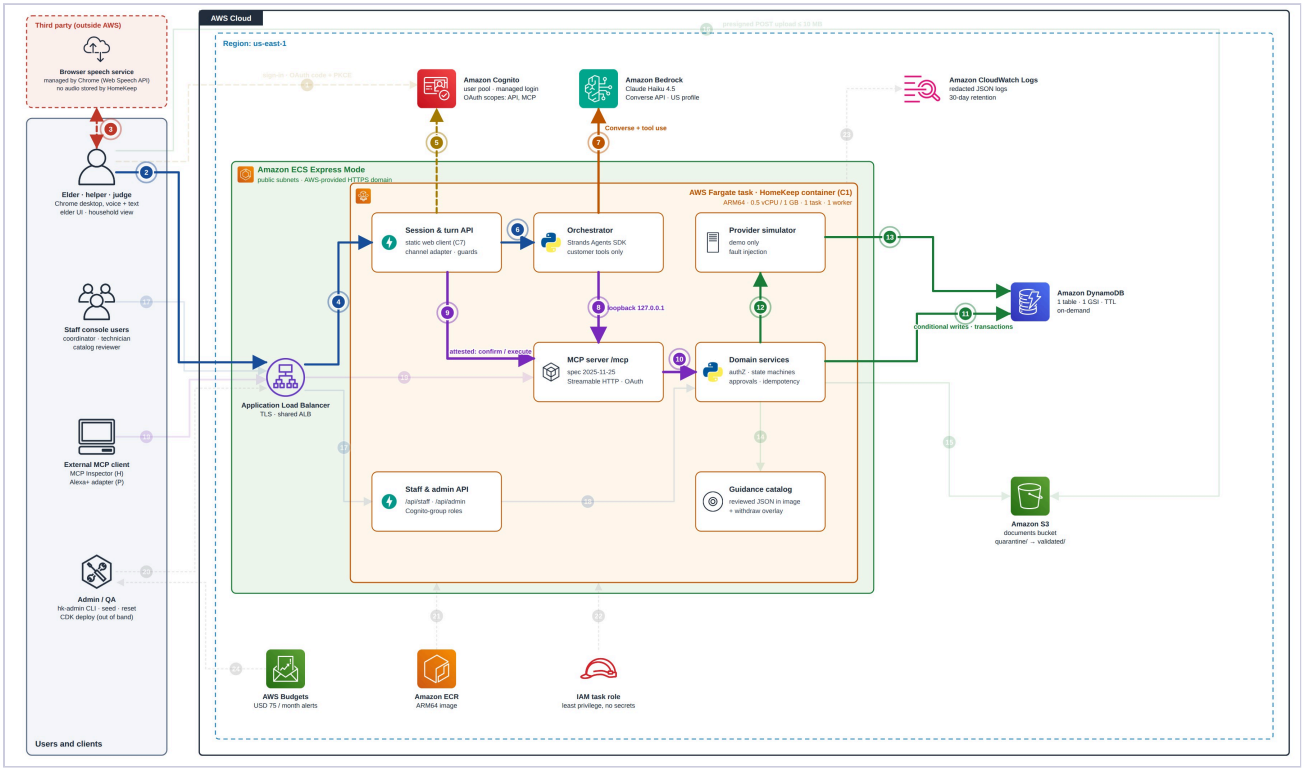


1. 3 Chrome recognises the speech and produces a final transcript.
2. 2 4 The client posts the turn with a new turn_id. The ALB forwards it to the session API.
3. 5 11 Token verified; membership read. A replayed turn_id would return the stored response here.
4. **channel guard** Deterministic guards run first: no stop/repeat command, no hazard phrase, no pending approval. (A phrase like “burning smell” would divert to the hazard path via arrow 9.)
5. 6 7 The orchestrator asks Bedrock what to do. The model chooses resolve_appliance.
6. 8 10 11 MCP → domain → DynamoDB finds exactly one “Bedroom AC” in this household.
7. 7 8 10 11 Next cycle: report_issue checks for an existing open issue, then writes a new one with the original wording (operation key prevents duplicates).
8. 7 8 10 14 Next cycle: get_guidance. Model unknown → NO_APPROVED_GUIDANCE, so the reply offers observations or a technician. Verified model → the approved first step with its source.
9. 11 Output guard checks the reply; the session checkpoint is saved.
10. 4 2 3 The response returns to the browser and Chrome speaks it: at most two sentences, one question.

> Every write happens before the reply is spoken, so a crash or reload never loses what the elder already said (FR-06, FR-10).

Part 2 — Flow C: Booking a demo technician with explicit approval

> *Elder: “Please send someone.” … HomeKeep reads back the booking … Elder: “Yes, book it.”*

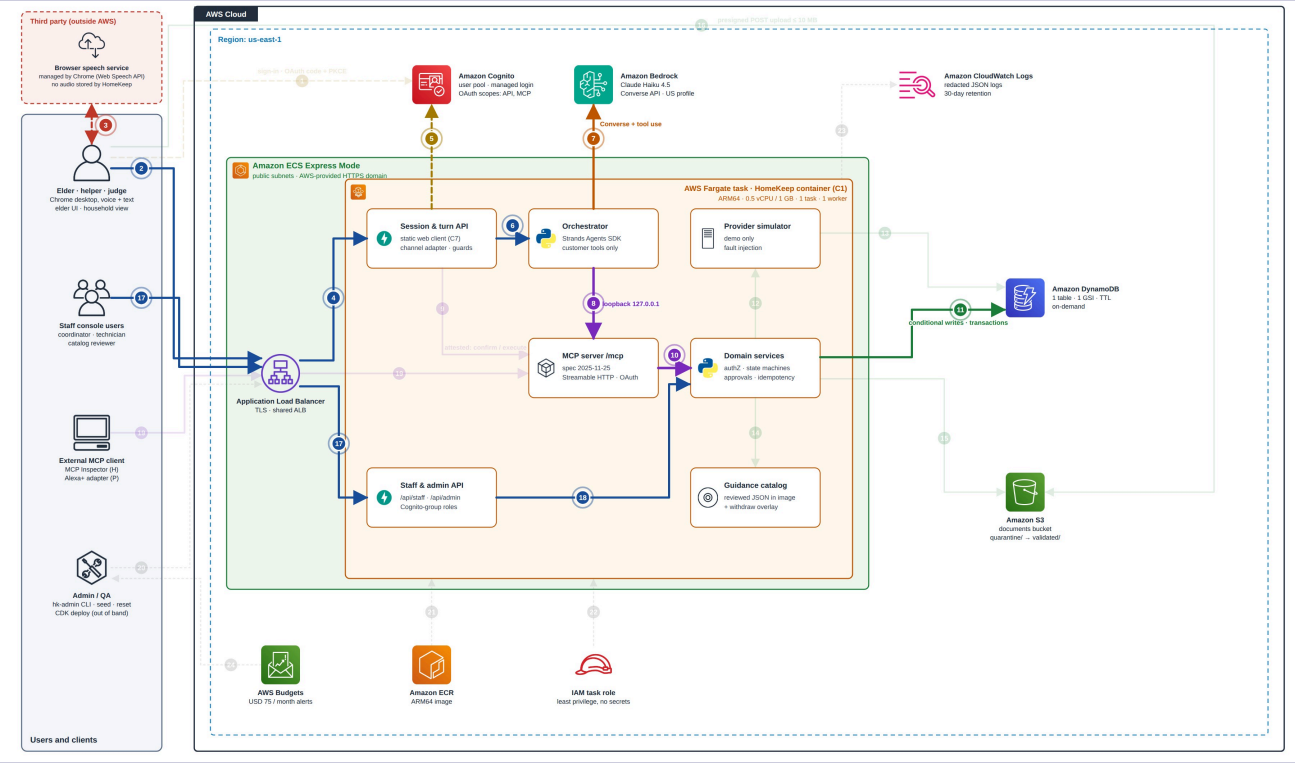


1. 3 2 4 5 6 7 The request reaches the orchestrator as in Flow B.
2. 8 10 11 draft_service_request creates a draft and asks only now for any missing address or contact.
3. 8 10 12 13 list_slots reads available demo slots. Listing never reserves a slot.
4. 8 10 11 prepare_action stores a pending approval (payload hash, versions, 5-minute expiry) and returns a fixed read-back: provider, date, window, fee or “unknown”, data shared, “demo”.
5. 3 2 4 Chrome speaks the read-back verbatim; the client reports when playback ended.
6. 3 2 4 5 Elder says “Yes, book it.” The turn arrives at the session API.
7. **channel guard** The approval guard, not the LLM, checks: approval unexpired, speech began after playback, whole utterance affirmative, not an echo, booking grant held. No arrows 6 or 7.
8. 9 10 11 Trusted MCP call confirm_action (attested). Domain recomputes the payload hash from current records. A changed fee or slot means refusal.
9. 9 10 12 13 Trusted MCP call execute_action. Domain submits to the provider with the operation key; the simulator takes the slot.
10. 11 On confirmation, one DynamoDB transaction writes the request, appointment, active-appointment marker, issue state, operation result and event.
11. 4 2 3 A server template is spoken: “Demo booking confirmed … No real technician will visit.”

> On a provider timeout the elder hears “pending”, never “confirmed”; reconciliation (12, 13) finds the single booking later. Rescheduling keeps the old slot until the new one is confirmed.

Part 2 — Flow D: Technician completes the visit; customer confirms the outcome

> *The technician marks the visit complete. Next morning the elder is asked whether the AC works.*

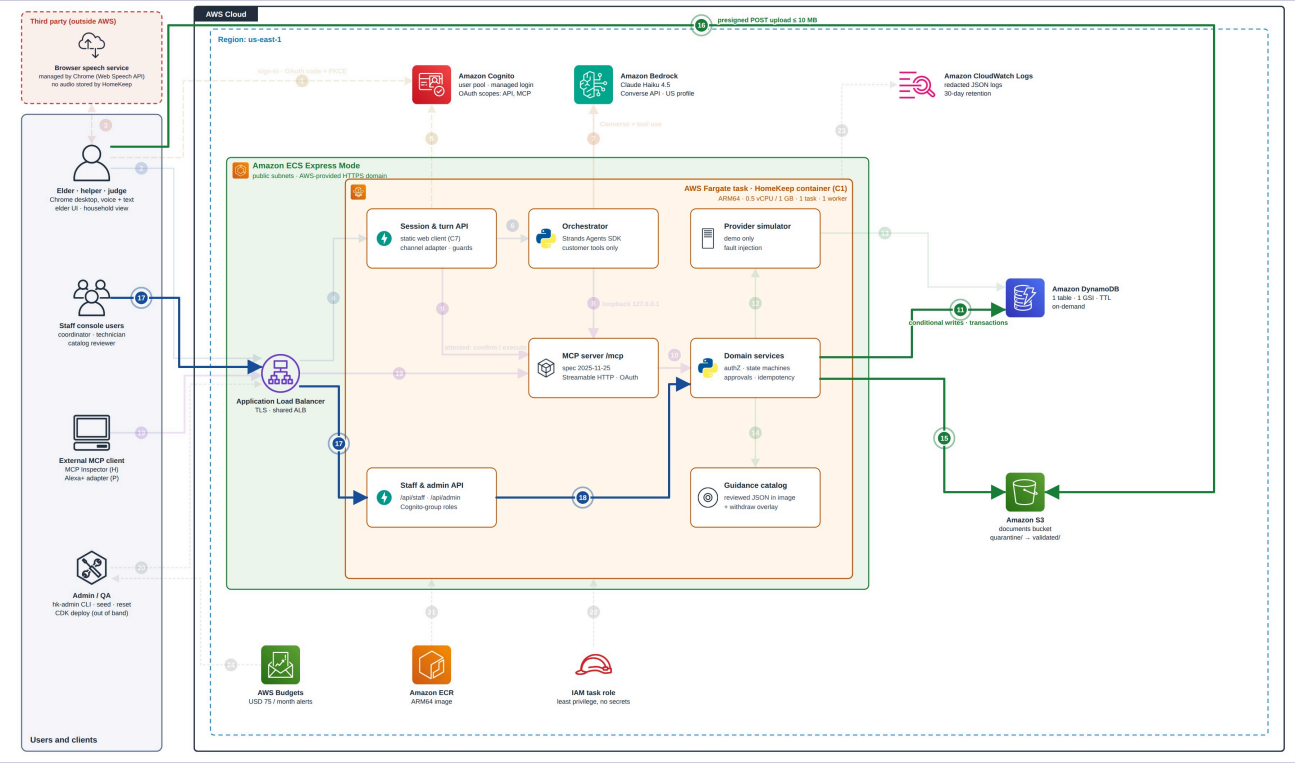


1. 17 The technician (signed in through Cognito) opens the assigned job in the staff console.
2. 18 11 POST VISIT_COMPLETED with event_id and expected_version. Domain checks the assignment and writes the event; the request becomes COMPLETED and the issue AWAITING_CUSTOMER. The issue is not closed.
3. 2 4 5 6 7 8 10 11 When the elder next speaks, get_context surfaces the completed visit and the orchestrator asks: “Is the AC cooling now?”
4. 8 10 11 confirm_resolution records the answer. “Still not cooling” returns the issue to SERVICE_NEEDED and offers a follow-up; “It works now” marks it RESOLVED. Closing is a separate, explicit request.
5. 3 The reply is spoken.

> Separating technician completion from customer-confirmed resolution is BRD risk R10's mitigation and one of HomeKeep's key product ideas (FR-17, AT-19).

Part 2 — Flow E: Optional document upload and model verification

> *A photo of the AC label is uploaded; a catalog reviewer verifies the model.*

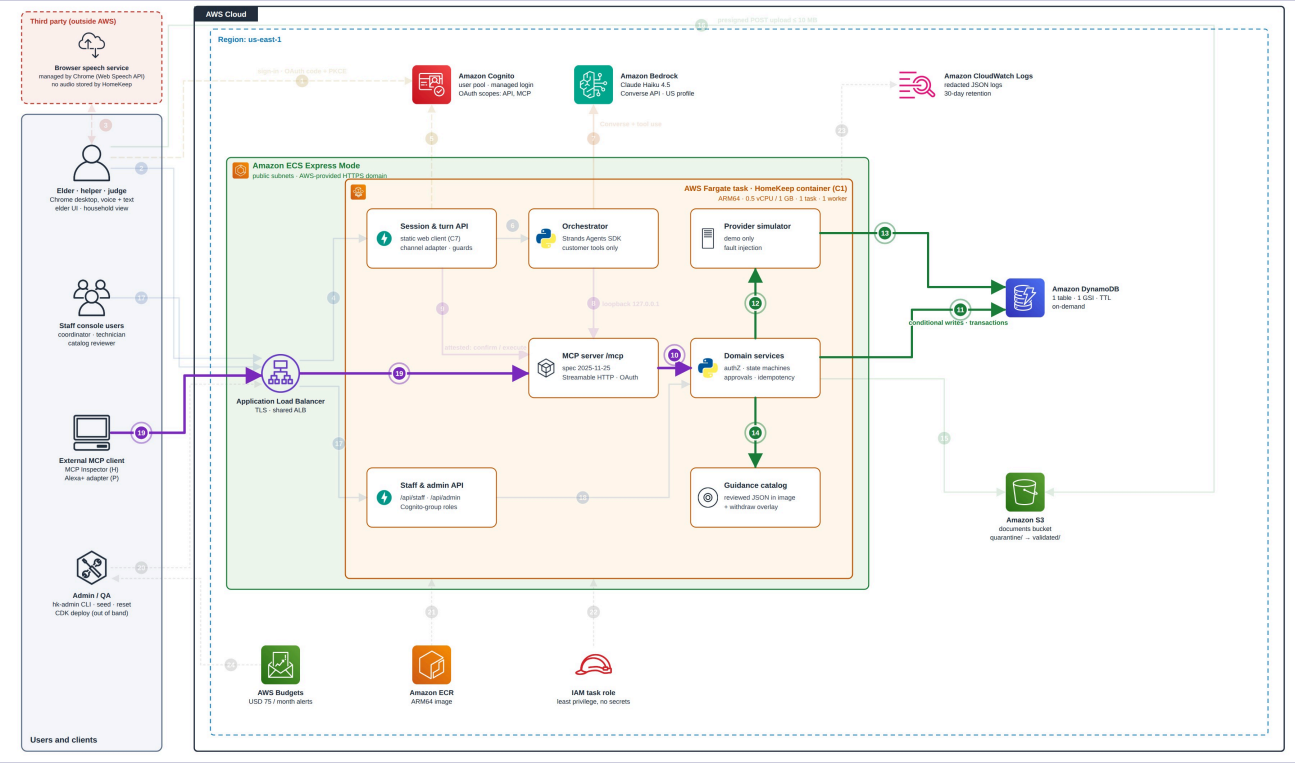


1. 17 18 15 A coordinator or technician asks for an upload form. Domain checks scope and issues a presigned POST limited to quarantine/, 10 MB and the declared type.
2. 16 The browser uploads the file directly to S3; it never passes through the container.
3. 17 18 15 11 The client calls finalize. Domain checks the file signature and size, moves the file to validated/ and records it as VALIDATED (or REJECTED).
4. 17 18 15 A catalog reviewer opens the case; the image is shown through a 5-minute presigned GET.
5. 18 11 verify-model sets the model to VERIFIED with the document reference. Only now can model-specific guidance unlock (Flow B, arrow 14).

A helper with the edit grant can upload the same way from the household view; those requests enter through arrows 2 and 4 and reach the same domain services. A missing document never blocks anything, and the agent has no document tool, so uploaded content cannot instruct it (FR-03, FR-04).

Part 2 — Flow F: External MCP client (judges; Alexa+ adapter in P)

> *A judge connects MCP Inspector to the public /mcp endpoint.*

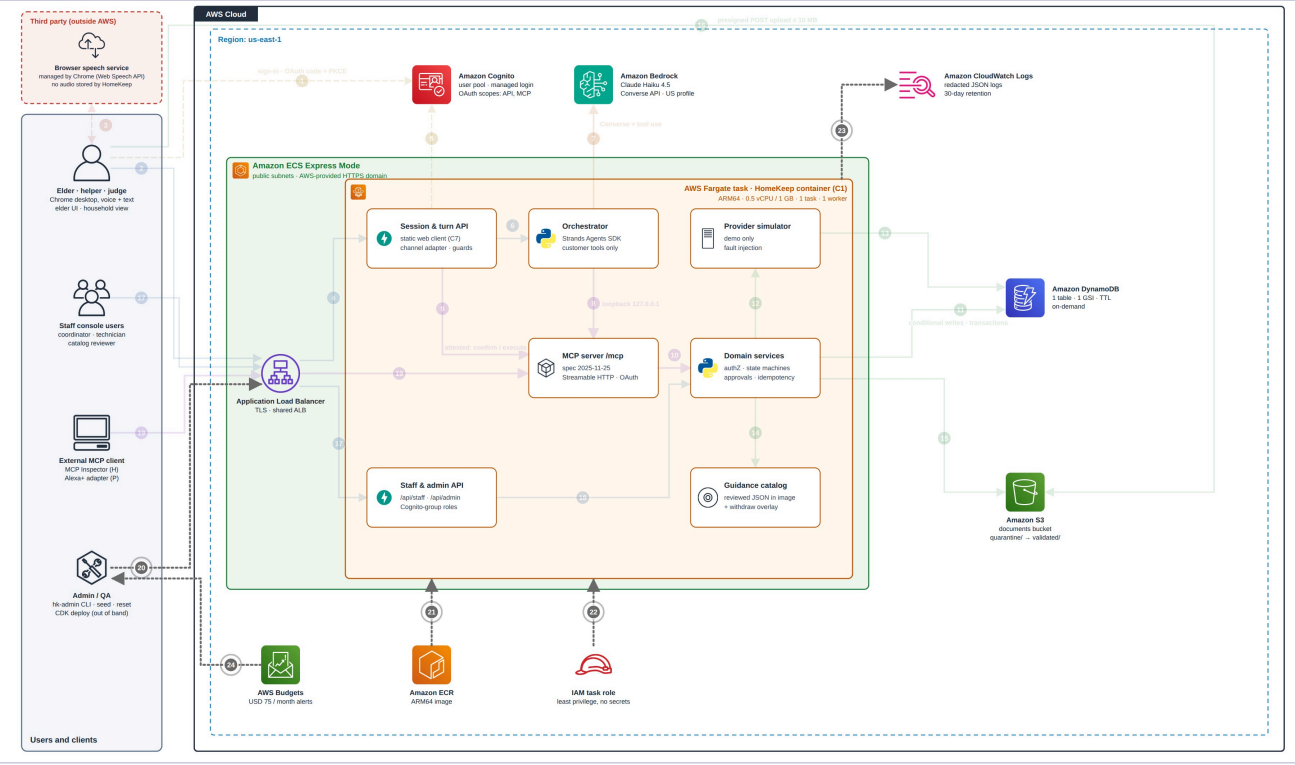


1. **19** An unauthenticated call gets 401 with a pointer to /.well-known/oauth-protected-resource, which names Cognito as the authorisation server.
2. **19** The judge signs in at Cognito with the mcp-inspector client (PKCE). Sign-in is the same Cognito flow as arrow 1, not drawn separately.
3. **19** initialize negotiates protocol version 2025-11-25 over Streamable HTTP (stateless, JSON responses).
4. **10** **11** **14** tools/list and tools/call run customer tools with the judge household's data (e.g. get_context, get_history, get_guidance).
5. **10** **12** **13** prepare_action works, but confirm_action and execute_action refuse the call: no channel attestation.

> This is the reusable integration surface. In P an Alexa+ adapter would call the same tools; approval capture would move into that trusted channel.

Part 2 — Flow G: Platform, operations and test controls

> *Deploy, run and watch the service through judging.*



1. **21** make deploy builds the ARM64 image and pushes it to ECR; ECS pulls it and starts one task.
2. **22** The task assumes its least-privilege IAM role; no credentials exist in code or configuration.
3. **23** Every request logs redacted structured JSON to CloudWatch Logs, joined by correlation id.
4. **20** Admin actions go through /api/admin: reset a judge household, withdraw a catalog item, set a provider fault for tests, purge a test household.
5. **24** AWS Budgets emails the owner at 50%, 80% and 100% of USD 75 per month.

The Ops page in the staff console (pending operations, manual-review items, errors, token cost estimate) reads DynamoDB through arrows 17, 18 and 11.